

# Security Report Summary

OWASP Juice Shop — ZAP Security Scan  
Generated from ZAP 2.17.0 on 08 October 2026

|                |                                     |
|----------------|-------------------------------------|
| Site           | http://demo.owasp-juice.shop        |
| Scanner        | OWASP ZAP 2.17.0                    |
| Method         | ZAP Spider + passive alert analysis |
| Spider status  | 100% complete                       |
| URLs processed | 5                                   |
| Nodes added    | 2                                   |
| ZAP alerts     | 19                                  |

## Observed Security Findings

| Finding                                      | Observed in ZAP |
|----------------------------------------------|-----------------|
| Content Security Policy (CSP) Header Not Set | Yes             |
| Cross-Domain Misconfiguration                | Yes             |
| Missing Anti-clickjacking Header             | Yes             |
| Cookie No HttpOnly Flag                      | Yes             |
| Cookie Without Secure Flag                   | Yes             |
| Cookie with SameSite Attribute None          | Yes             |
| Cookie without SameSite Attribute            | Yes             |
| Private IP Disclosure                        | Yes             |
| Server / X-Powered-By Information Disclosure | Yes             |
| Strict-Transport-Security Disabled / Not Set | Yes             |

## Security Header Review

The ZAP session visibly reported CSP, anti-clickjacking and Strict-Transport-Security findings. These controls are important for reducing common web risks such as XSS, clickjacking and weak transport security. The report records only what was observed in this ZAP session; it does not claim that every possible vulnerability was manually tested.

# Missing / Security Header Summary

Findings below are based on the user's actual ZAP alert results.

| Control                             | Result in this scan         | Purpose                                                         |
|-------------------------------------|-----------------------------|-----------------------------------------------------------------|
| Content-Security-Policy             | Not Set alert               | Restricts allowed content and scripts; helps reduce XSS impact. |
| Anti-clickjacking / X-Frame-Options | Missing alert               | Helps prevent clickjacking through framing.                     |
| Strict-Transport-Security           | Disabled / Not Set alert    | Helps enforce HTTPS for future connections.                     |
| X-Content-Type-Options              | Not independently confirmed | Helps prevent MIME-type sniffing.                               |
| Referrer-Policy                     | Not independently confirmed | Controls referrer information sent by the browser.              |
| Permissions-Policy                  | Not independently confirmed | Restricts browser features and APIs.                            |

## Risk Summary

The scan produced 19 ZAP alerts. Visible findings include missing or weak security headers, cookie security issues, cross-domain configuration and information disclosure. OWASP Juice Shop is intentionally insecure and is designed for security training and security-tool testing, so these results are expected as part of the exercise.

## Evidence

Primary evidence: ZAP 2.17.0 Alerts panel and the generated HTML report  
2026-10-08-ZAP-Report-demo.owasp-juice.shop.html.